

Investigación 1 (grupal): temas emergentes de ciberseguridad

Revisión de literatura, demo y presentación (15 min)

CE-1115 Seguridad de la Información
Instituto Tecnológico de Costa Rica — Escuela de Ingeniería en Computadores
MSc. Andrés Vargas Rivera

Semestre II — 2026

Fecha de entrega y presentación: 29/09/2026

El **29 de setiembre de 2026** se entregan el informe, el PDF del atributo IN y las diapositivas. Las presentaciones con demo son en la **misma sesión de clase** de ese día.

Preferencia de tema: publicar en el grupo de Telegram (**integrantes, tema**) antes del **jueves 10 de setiembre de 2026, antes de la clase**. Un tema por grupo; no se repiten temas si hay 9 grupos o menos.

Actividad y ponderación (10 %)

- **Revisión de literatura:** localizar, leer y sintetizar al menos **cinco** trabajos válidos sobre un **tema emergente** de ciberseguridad (lista más abajo); relacionarlos con el curso (tríada CID, amenazas, controles, ética) y entregar un informe en PDF de **máximo 5 páginas** en **formato de dos columnas** (sin anexos).
- **Comunicación:** presentación de **al menos 15 minutos** con **demo o ejemplo práctico** (en vivo o en video) en entorno autorizado.
- **Atributo Investigación (IN):** PDF **aparte** del informe, con **portada propia**, texto literal de IN1–IN5 y respuestas del grupo; en la defensa, preguntas orales alineadas a esos indicadores.

Ponderación (cada porcentaje es sobre la nota final del curso; total **10 %**):

Componente	Peso	Qué se evalúa
Documento (informe + atributo IN)	5 %	Cinco fuentes discutidas; matriz de revisión; síntesis tipo <i>survey</i> ; impacto actual; y el PDF de atributo IN con sus cinco indicadores (IN1–IN5). Rúbrica única de 10 criterios.
Presentación (exposición, demo y defensa)	5 %	Claridad, tiempo (mínimo 15 min), demo o ejemplo práctico enlazado a los papers, y la defensa individual de cada integrante (dominio, ética, y los cinco indicadores IN respondidos oralmente). Rúbrica única de 14 criterios.

Cada componente se evalúa con **una sola rúbrica** (ver más adelante): la del **Documento** agrupa lo que antes eran informe y PDF de atributo IN por separado; la de **Presentación** agrupa exposición, demo y las dos defensas (general e individual).

Fuentes: qué cuenta como una de las cinco

En un tema **emergente** rara vez hay cinco papers clásicos con revisión por pares; buena parte de lo mejor que se escribe hoy sobre el tema vive en informes técnicos, avisos oficiales de seguridad y publicaciones de ingeniería con autor identificable. Se aceptan **tres categorías**, y las cinco fuentes pueden combinarlas:

- **Académicas (mínimo dos de las cinco).** Congreso o revista con revisión por pares, *surveys*, SLR, tesis con método claro (ACM, IEEE, Springer, USENIX, NDSS, CCS, etc.). Los **preprints** de arXiv (**cs.CR**) cuentan aquí: son la fuente natural en temas donde aún no hay mucho publicado con revisión por pares, pero contrástenlos con literatura publicada cuando exista.
- **Técnicas con autoría identificable.** Informes de organismos serios (NIST, ENISA, OWASP, MITRE, CISA); *advisories* oficiales de seguridad (de un CERT, de un fabricante); publicaciones de ingeniería o de investigación de seguridad de una empresa reconocida (p. ej. el blog de ingeniería de Google, el *threat research* de una empresa de seguridad, la documentación técnica de un estándar como NIST SP 800-207). Debe tener **autor o equipo firmante** y **fecha**; no vale una página sin autoría clara.
- **De actualidad, para el impacto (no sustituyen a las anteriores).** Un anuncio oficial de producto, un comunicado de una empresa, un reporte de incidente publicado por la organización afectada o por un investigador con nombre. Son las que mejor alimentan la sección de *Impacto actual en tecnologías* del informe, aunque no sean “papers”.

No cuentan como ninguna de las cinco: entradas de blog sin autor identificable, foros, videos sin transcripción ni fuente citable, Wikipedia (solo para orientarse), y notas periodísticas que no citen su fuente primaria. Si citan un medio periodístico, procuren llegar hasta el informe, *advisory* o comunicado original que ese medio referencia, y citen ese original.

Estructura del informe (formato *summary paper*)

El informe debe seguir la estructura estándar de un artículo de síntesis (*survey paper*), en **dos columnas**, máximo **5 páginas**:

1. **Resumen (*abstract*)**. 150–200 palabras: qué tema abordan, qué encontraron, por qué importa.
2. **Introducción**. Qué es el tema emergente, por qué es relevante *hoy*, qué problema de seguridad plantea.
3. **Metodología de búsqueda**. Cómo buscaron los cinco papers: bases de datos, palabras clave, criterios de inclusión/exclusión.
4. **Desarrollo / estado del arte**. Síntesis cruzada de los cinco (o más) trabajos: qué proponen, qué métodos usan, qué encuentran. Incluye la **matriz de revisión** (tabla con: referencia, problema, método, datos o entorno si aplica, hallazgo principal, limitación).
5. **Discusión / hallazgos propios del grupo**. Contradicciones entre trabajos, vacíos de investigación, riesgos no resueltos; conexión explícita con conceptos del curso (tríada CID, un principio de la Clase 4, una política de la Clase 5, etc.).
6. **Impacto actual en tecnologías y organizaciones. Obligatorio**. Aterrizar el tema en el presente: qué empresas, productos, servicios o sectores lo enfrentan *hoy*; al menos **un caso o producto real** (con nombre propio y fecha) donde el tema emergente ya cause un efecto medible — una brecha, un cambio de producto, una nueva norma, una inversión, un titular verificable. No basta con decir “esto es importante”; hay que mostrar *dónde* y *en qué* ya se nota.
7. **Conclusiones**. Síntesis final: a partir del impacto mostrado, hacia dónde va el tema, qué le falta a la industria o a la academia, y qué debería vigilar un profesional de seguridad en los próximos años.
8. **Referencias**. Norma de citación consistente (APA, IEEE o ACM) de principio a fin.

Entregas

- **Informe PDF** — máx. **5 páginas** (sin anexos), en **formato de dos columnas** (plantilla IEEE o ACM, o equivalente), con la estructura de *summary paper* de la sección anterior.
- **Matriz de revisión** — tabla con al menos: referencia; problema; método; datos o entorno (si aplica); hallazgo principal; limitación. No copiar *abstracts*.
- **PDF atributo IN** — *documento aparte* del informe, con **portada propia** (no cuenta en las 5 páginas del informe).
 - **Nombre del archivo:** claro; p. ej. Atributo_IN_grupoX.pdf.
 - **Portada:** integrantes, curso, tema asignado, fecha y título que indique el atributo **Investigación (IN)**.
 - **Cuerpo del documento:** indicar el atributo **Investigación (IN)** al inicio del contenido.
 - **Definición:** copiar **literalmente** el párrafo de definición del apartado *Texto oficial del atributo IN* más abajo.
 - **Bloques IN1, IN2, ..., IN5** (en ese orden): primero el **texto literal** del indicador; debajo, la **respuesta del grupo** con ejemplos concretos (secciones del informe, matriz de papers, demo, decisiones, limitaciones).
- **Diapositivas** — PDF u otro formato acordado.
- **Demo o ejemplo práctico** — dentro de los **15 minutos mínimos** (orientativo 5–8 min). Puede ser en **vivo** (herramienta, tecnología o experimento identificado en la investigación) o **en video** si el ejemplo no puede correrse en el aula (p. ej. un deepfake generado previamente, una demo de un venue académico). Entorno propio (VM, contenedor, lab del curso, nube educativa). No atacar terceros sin autorización escrita; no usar datos personales reales.

Texto oficial del atributo Investigación (IN)

Copien la definición y los cinco indicadores **tal como aparecen aquí** en el PDF del atributo IN, y escriban debajo la respuesta del grupo. En la defensa oral el docente puede preguntar sobre cada indicador.

Definición. Capacidad para conducir investigaciones de problemas complejos por medio de conocimientos y métodos apropiados, incluyendo el diseño de experimentos, análisis e interpretación de datos y síntesis de información para proveer conclusiones válidas.

Indicadores.

1. **IN1.** Identifica el problema complejo de ingeniería a investigar.

En el PDF IN: qué problema concreto del tema emergente asignado investigan y por qué importa ahora.

2. **IN2.** Diseña una propuesta de investigación.

En el PDF IN: preguntas guía, criterios de búsqueda y de selección de fuentes, y alcance.

3. **IN3.** Ejecuta la metodología del plan de investigación para la obtención de datos relevantes.

En el PDF IN: cómo aplicaron el plan (lectura, matriz, demo o ejemplo alineado a lo leído).

4. **IN4.** Analiza los datos obtenidos en el desarrollo de la investigación.

En el PDF IN: comparación entre trabajos, contradicciones, limitaciones o riesgos (no solo listar).

5. **IN5.** Elabora conclusiones a partir de la síntesis y análisis de los resultados de la investigación.

En el PDF IN: conclusiones de conjunto (estado del arte, vacíos, implicaciones, e **impacto actual** en tecnologías u organizaciones) coherentes con IN1–IN4.

Presentación (mínimo 15 minutos)

1. Contexto: qué es el tema emergente y por qué importa hoy (aprox. 2 min).
2. Cómo buscaron y eligieron los papers (aprox. 2 min).
3. Síntesis cruzada de los cinco o más trabajos (aprox. 5–6 min).
4. Demo o ejemplo práctico (en vivo o video) enlazado a la literatura (aprox. 5–6 min).
5. Conclusiones (aprox. 1–2 min).

Preguntas: fuera de esos 15 minutos, el docente conversa con **cada** integrante. Hay dos bloques de nota (general e IN); en el bloque IN las preguntas son concretas (p. ej. problema, búsqueda, evidencia, análisis, conclusiones) y deben cuadrar con lo escrito en el PDF del atributo IN.

Temas emergentes (preferencia del grupo y asignación)

Antes del **jueves 10 de setiembre de 2026, antes de la clase**, cada grupo publica en el **grupo de Telegram** del curso su preferencia en **una sola línea** con el formato **integrantes, tema** (nombres o apellidos del equipo, coma, número del tema). El docente confirma o asigna el tema definitivo por grupo; **no se repiten temas** entre grupos si hay 9 o menos.

Cada grupo trabaja **un** tema. El informe y la charla deben dar una **visión de conjunto** del estado del arte; la demo o ejemplo práctico debe **ilustrar** ideas de la literatura, no ser un truco aislado.

Tema 1: Prompt injection y jailbreaks de modelos de lenguaje

Ámbito. Técnicas para manipular un LLM y hacerle saltarse sus reglas de seguridad (*system prompt*); por qué es una categoría de vulnerabilidad nueva, distinta a las clásicas de software; defensas propuestas en la literatura.

Aporte al curso. Conecta con control de acceso (¿quién decide qué puede pedir el modelo?), ingeniería social aplicada a una IA, y los principios de diseño seguro de la Clase 4.

Demo posible. Documentar (en video o en vivo, contra un modelo propio o de prueba) un caso de *prompt injection* conocido y su mitigación.

Tema 2: Deepfakes y su detección

Ámbito. Cómo se generan deepfakes de voz o video, casos de fraude documentados, y el estado del arte en herramientas de detección.

Aporte al curso. Relaciona con integridad y autenticidad de la información, ingeniería social, y el debate de privacidad de la Clase 3.

Demo posible. Generar un deepfake de audio simple con voz **propia y consentida** y probarlo contra una herramienta detectora (en vivo o en video).

Tema 3: Criptografía post-cuántica

Ámbito. Por qué la computación cuántica amenaza RSA y ECC; el ataque “*harvest now, decrypt later*”; los algoritmos ya estandarizados por NIST (Kyber, Dilithium).

Aporte al curso. Anticipa los temas de criptografía simétrica/asimétrica y firmas digitales que se ven más adelante en el curso.

Demo posible. Intercambio de claves post-cuántico con una librería (p. ej. `liboqs`, Python) en un entorno propio.

Tema 4: Ransomware como servicio (RaaS)

Ámbito. El modelo de negocio criminal detrás del ransomware moderno: afiliados, doble y triple extorsión; casos recientes documentados en la literatura o en informes técnicos serios.

Aporte al curso. Ilustra disponibilidad, integridad, políticas de respaldo (Clase 5) y el marco de informática forense (Clase 8).

Demo posible. Simulación de cifrado de archivos propios en un entorno aislado (VM o contenedor), o un video documentado de una cadena de ataque real.

Tema 5: Ataques a la cadena de suministro de software

Ámbito. Lógica de ataques como SolarWinds; paquetes de código abierto envenenados en npm o PyPI; por qué las dependencias son un vector de ataque creciente.

Aporte al curso. Conecta con integridad del software, propiedad intelectual (Clase 6) y principios de mínimo privilegio.

Demo posible. Analizar un caso documentado de paquete malicioso, o instalar un paquete “trampa” propio (inofensivo) en un entorno aislado para mostrar el mecanismo.

Tema 6: Seguridad de dispositivos IoT

Ámbito. Por qué los dispositivos IoT son el eslabón más débil de una red; botnets tipo Mirai; literatura sobre vulnerabilidades comunes y propuestas de mitigación.

Aporte al curso. Usa las técnicas de reconocimiento de red (nmap) vistas en el Taller de la Clase 7; conecta con hardware hacking de esa misma clase.

Demo posible. Escanear (con nmap, en la red de laboratorio) dispositivos IoT propios para identificar puertos y servicios expuestos.

Tema 7: Arquitecturas de confianza cero (Zero Trust)

Ámbito. El modelo “nunca confíes, siempre verifica”; por qué reemplaza al perímetro de red clásico; el estándar NIST SP 800-207.

Aporte al curso. Se conecta directo con ABAC (Clase 10) y con la autenticación multifactor que se ve más adelante en el curso.

Demo posible. Configurar un ejemplo simple de autenticación contextual o acceso condicional con una herramienta gratuita (p. ej. Authelia, Cloudflare Access en su capa gratuita).

Tema 8: Envenenamiento de datos y robo de modelos de IA

Ámbito. Cómo se envenena un conjunto de datos de entrenamiento (*data poisoning*) o se “roba” un modelo por consultas repetidas (*model extraction*); literatura sobre ataques y defensas.

Aporte al curso. Amplía el concepto de integridad a un contexto nuevo (los datos de entrenamiento como activo); prepara el terreno de la Investigación 2 del curso (“CIA en IA”).

Demo posible. Con un modelo de juguete (p. ej. `scikit-learn`), mostrar cómo unos pocos datos maliciosos cambian su comportamiento.

Tema 9: Reconocimiento facial, biometría y vigilancia

Ámbito. El debate técnico-legal del reconocimiento facial en espacios públicos; sesgos algorítmicos documentados en la literatura; marco costarricense (Ley 8968) frente a casos internacionales.

Aporte al curso. Retoma la Clase 3 (privacidad) y anticipa la biometría que se ve más adelante en el curso (Clase 16).

Demo posible. Usar una librería de reconocimiento facial de código abierto sobre una foto o video propio (con consentimiento), mostrando el mecanismo y su margen de error.

Rúbricas (escala 0 a 5 por criterio)

Cada fila de criterio en las tablas siguientes recibe un entero de **0 a 5**. La primera tabla define el significado de cada puntaje (misma escala en todos los bloques).

Pts.	Qué significa (cumplimiento)
5	Cumple de manera excelente. Supera lo esperado para el curso: contenido completo, correcto y bien fundamentado; comunicación clara; sin omisiones relevantes respecto al criterio.
4	Cumple claramente (notable). Cumple lo esperado y con buen detalle; podría haber pequeños márgenes de mejora que no afectan el fondo del criterio.
3	Cumple de forma satisfactoria / medianamente. Cumple lo esencial del criterio de forma aceptable, pero con lagunas menores, menos profundidad o presentación mejorable; el trabajo es válido pero no sobresaliente.
2	Cumple de manera elemental / por debajo de lo esperado. Hay intento visible pero incompleto: partes importantes del criterio faltan, son confusas o con errores frecuentes; requiere mejora sustancial.
1	Cumple de forma insuficiente / casi no cumple. Aporte mínimo o muy deficiente respecto al criterio: muy incompleto, irrelevante o con errores graves; apenas alcanza a tocar el aspecto evaluado.
0	No cumple / no aplica en la entrega. Ausente, no entregado, ilegible, copiado sin aporte propio evidente, o incumple requisitos mínimos del criterio (equivalente a no cumplir).

Rúbrica 1 — Documento (informe + atributo IN)

Criterio	Puntaje (0–5)
1. Fuentes y citación. Cinco fuentes válidas (mínimo dos académicas), con autoría identificable en las técnicas; buen equilibrio entre las tres categorías admitidas; pertinencia al tema emergente y citación consistente (APA, IEEE o ACM). 2. Matriz o tabla de revisión. Tabla/matriz completa (referencia, problema, método, datos o entorno si aplica, hallazgo, limitación); útil para comparar trabajos, no meramente decorativa. 3. Síntesis crítica y estado del arte. Va más allá del resumen por paper: contrasta resultados, identifica vacíos o contradicciones y ofrece mirada de conjunto (<i>survey</i>). 4. Alineación con el curso e impacto actual. Conexión explícita con la tríada CID, un principio, política o control visto en clase, y un caso o producto real y verificable (con nombre y fecha) donde el tema emergente ya tenga efecto hoy en alguna tecnología u organización. 5. Redacción, estructura y formato. Sigue la estructura de <i>summary paper</i> (resumen, introducción, metodología, desarrollo, discusión, impacto actual, conclusiones, referencias); cumple tope de 5 páginas en dos columnas. 6. IN1 (problema). El PDF de atributo IN identifica con claridad el problema complejo de ingeniería abordado (en el marco del tema emergente asignado) y su relevancia actual; no es genérico. 7. IN2 (propuesta). Describe la propuesta de investigación: preguntas, criterios de búsqueda y selección de fuentes, alcance; no es un listado inconexo. 8. IN3 (ejecución). Evidencia la ejecución del plan (lectura sistemática, matriz, evidencia en la demo alineada a lo revisado). 9. IN4 (análisis). Analiza la evidencia reunida (comparación entre trabajos, contradicciones, limitaciones, riesgos técnicos), no solo describe. 10. IN5 (conclusiones). Presenta conclusiones a partir de síntesis y análisis (estado del arte, vacíos, implicaciones, impacto actual), coherentes con IN1–IN4.	
Subtotal documento	/50 → hasta 5 %

Rúbrica 2 — Presentación (exposición, demo y defensa individual)

Criterio	Puntaje (0–5)
1. Organización y claridad. Introducción, desarrollo y cierre; lenguaje claro; diapositivas legibles (tipografía, contraste, sin exceso de texto). 2. Tiempo y roles. Cumple el mínimo de 15 minutos; reparto equilibrado o justificado de la palabra entre integrantes. 3. Contenido oral de la literatura. Expone con rigor la síntesis de los papers (ideas, métodos, hallazgos), no solo lista títulos. 4. Demo o ejemplo práctico. La demostración (en vivo o en video) funciona o se documenta con claridad; es segura y ética (entorno propio, autorizado); ilustra un concepto del tema. 5. Integración literatura–demo. Explica de forma explícita cómo la demo o ejemplo se relaciona con lo leído en la literatura (no demo aislada del marco teórico). 6. Dominio del propio aporte (defensa). Cada integrante responde sobre la parte de literatura, demo o análisis que le correspondió; demuestra haber construido el trabajo y no solo haber asistido. 7. Precisión conceptual (defensa). Usa términos del curso correctamente (amenazas, controles, cripto, autenticación, etc.) sin confusiones graves. 8. Ética y legalidad (defensa). Reconoce límites de la demo, uso autorizado de entornos y datos; no propone acciones ilegales o no éticas. 9. Argumentación y honestidad (defensa). Fundamenta respuestas; admite límites del estudio o de la evidencia cuando se le pregunta. 10. IN1 oral. Responde con claridad ante preguntas específicas sobre el problema investigado y su rol en acotarlo o delimitarlo. 11. IN2 oral. Responde con solvencia sobre la propuesta o el diseño de la indagación que le correspondió. 12. IN3 oral. Aclara acciones concretas de ejecución (búsqueda, experimentación, demo) y evidencias que manejó. 13. IN4 oral. Argumenta sobre análisis o interpretación de evidencias ante preguntas puntuales (no solo memoriza conclusiones del grupo). 14. IN5 oral. Formula o sustenta conclusiones coherentes con el análisis y admite límites cuando corresponde.	
Subtotal presentación (grupal, criterios 1–5; individual, 6–14 por integrante)	/70 → hasta 5 %

Nota de aplicación: los criterios 1–5 se califican **una vez por grupo** (la exposición y la demo son colectivas); los criterios 6–14 se califican **por integrante**, en la conversación individual que sigue a los 15 minutos de exposición.

Checklist de entrega

- ✓ PDF del informe (máx. **5 páginas** sin anexos, **dos columnas**, estructura de *summary paper*): portada, matriz o tabla de papers, bibliografía, conclusiones al **tema emergente asignado**.
- ✓ PDF **aparte** del atributo IN, con **portada propia**, según la lista anidada de la sección *Entregas*.
- ✓ Preferencia de tema publicada en Telegram (**integrantes, tema**) antes del **jueves 10 de setiembre de 2026, antes de la clase**.
- ✓ PDF de diapositivas (o formato acordado).
- ✓ Demo o ejemplo práctico listo (en vivo o en video) para la presentación de **mínimo 15 minutos**.